HTTP Observatory Report

Report Feedback

Scan summary: keeply.work

B

↗ since last scan

Score: 70 / 100
Scan Time: Very soon
Tests Passed: 8 / 10

Scan results

Scoring

Test	Score	Reason	Recommenda
Content Security Policy (CSP)	-20 ✗	Content Security Policy (CSP) implemented unsafely. This includes `'unsafe-inline'` or `data:` inside `script-src`, overly broad sources such as `https:` inside `object-src` or `script-src`, or not restricting the sources for `object-src` or `script-src`.	Remove `unsafe-inline` `script-src`, overly broa `object-src` and `script-` ensure `object-src` and set.
Cookies	-	No cookies detected	None
Cross Origin Resource Sharing (CORS)	0 ✓	Content is not visible via cross-origin resource sharing (CORS) files or headers.	None
Redirection	0 ✓	Initial redirection is to HTTPS on same host, final destination is HTTPS	None
Referrer Policy	0* ✓	`Referrer-Policy` header set to `no-referrer`, `same-origin`, `strict-origin` or `strict-origin-when-cross-origin`.	None
Strict Transport Security (HSTS)	-10 ✗	`Strict-Transport-Security` header set to less than six months (15768000).	Increase HSTS period.
Subresource Integrity	0* ✓	Subresource Integrity (SRI) is implemented and all scripts are loaded from a similar origin.	None

Test	Score	Reason	Recommenda
X-Content-Type-Options	0 ✓	**`X-Content-Type-Options`** header set to **`nosniff`**.	None
X-Frame-Options	0* ✓	**`X-Frame-Options`** (XFO) implemented via the CSP frame-ancestors directive.	None
Cross Origin Resource Policy	0* ✓	Cross Origin Resource Policy (CORP) implemented, prevents leaks into cross-origin contexts.	None

* Normally awards bonus points, however, in this case they are not included in the overall score (find out why).

CSP analysis

✕ Content Security Policy (CSP) implemented unsafely. This includes **`'unsafe-inline'`** or **`data:`** inside **`script-src`**, overly broad sources such as **`https:`** inside **`object-src`** or **`script-src`**, or not restricting the sources for **`object-src`** or **`script-src`**.

Test	Result	Info
Blocks execution of inline JavaScript by not allowing **`'unsafe-inline'`** inside **`script-src`**	✕	Blocking the execution of inline JavaScript prov strongest protection against cross-site scriptin Moving JavaScript to external files can also he site more maintainable.
Blocks execution of JavaScript's **`eval()`** function by not allowing **`'unsafe-eval'`** inside **`script-src`**	✓	Blocking the use of JavaScript's **`eval()`** functic prevent the execution of untrusted code.
Blocks execution of plug-ins, using **`object-src`** restrictions	✓	Blocking the execution of plug-ins via **`object-s`** as inherited from **`default-src`** can prevent atta loading Flash or Java in the context of your pag
Blocks inline styles by not allowing **`'unsafe-inline'`** inside **`style-src`**	✕	Blocking inline styles can help prevent attacker modifying the contents or appearance of your p styles to external stylesheets can also help ma more maintainable.
Blocks loading of active content over HTTP or FTP	✓	Loading JavaScript or plugins can allow a man to execute arbitrary code or your website. Rest policy and changing links to HTTPS can help pr
Blocks loading of passive content over HTTP or FTP	✓	This site's Content Security Policy allows the lo passive content such as images or videos over protocols such as HTTP or FTP. Consider chan load them over HTTPS.

Test	Result	Info
Clickjacking protection, using `frame-ancestors`	✓	The use of CSP's `frame-ancestors` directive of grained control over who can frame your site.
Deny by default, using `default-src 'none'`	✗	Denying by default using `default-src 'none'` your Content Security Policy doesn't allow the resources you didn't intend to allow.
Restricts use of the `<base>` tag by using `base-uri 'none'`, `base-uri 'self'`, or specific origins.	✓	The `<base>` tag can be used to trick your site in scripts from untrusted origins.
Restricts where `<form>` contents may be submitted by using `form-action 'none'`, `form-action 'self'`, or specific URIs	✓	Malicious JavaScript or content injection could sensitive form data is submitted to or create ad for data exfiltration.
Uses CSP3's `'strict-dynamic'` directive to allow dynamic script loading (optional)	-	`'strict-dynamic'` lets you use a JavaScript sh load all your site's JavaScript dynamically, with track `script-src` origins.

Cookies

No cookies detected

Raw server headers

Header	Value
Age	0
Nel	{"report_to":"cf-nel","success_fraction":0.0,"max_age":604800}
Via	1.1 varnish
Date	Fri, 24 Apr 2026 13:48:28 GMT
Vary	Accept-Encoding
Cf-Ray	9f1590d7aa5c27e2-SEA
Server	cloudflare
Alt-Svc	h3=":443"; ma=86400
Expires	Fri, 24 Apr 2026 13:58:28 GMT
X-Cache	MISS
X-Timer	S1777038509.765869,VS0,VE78

Header	Value
Report-To	{"group":"cf-nel","max_age":604800,"endpoints": [{"url":"https://a.nel.cloudflare.com/report/v4?s=LBEIi76Z6G3JAuzNVIVwBzMgRQr%2FpeC%2BBtzvhRqchOtufJt%2BdVC vyYNz3rTbrNV%2FyFWXNFoLKaI3EyHF3UcgtGIq4nkmGu49MYUhy%2Bvq 2Bg%3D%3D"}]}
Connection	close
X-Served-By	cache-bfi-krnt7300080-BFI
Content-Type	text/html; charset=utf-8
X-Cache-Hits	0
Cache-Control	max-age=600
Last-Modified	Fri, 24 Apr 2026 13:38:38 GMT
Server-Timing	cfCacheStatus;desc="DYNAMIC", cfEdge;dur=14,cfOrigin;dur=86
X-Proxy-Cache	MISS
Cf-Cache-Status	DYNAMIC
Referrer-Policy	strict-origin-when-cross-origin
X-Frame-Options	DENY
Transfer-Encoding	chunked
Permissions-Policy	camera=(), microphone=(), geolocation=(), payment=(), usb=(), magnetomet gyroscope=(), accelerometer=(), autoplay=(), fullscreen=(self)
X-Fastly-Request-Id	238603cec925dddc25d8c4a40c8fd9e4a7ce3ace
X-Github-Request-Id	D5BC:1C039A:28305F1:2926424:69EB74AA
X-Content-Type-Options	nosniff
Content-Security-Policy	default-src 'self'; script-src 'self' 'unsafe-inline' https://www.googletagmana https://static.cloudflareinsights.com; style-src 'self' 'unsafe-inline'; img-src https://www.google-analytics.com; font-src 'self'; connect-src 'self' https://docs.google.com https://*.google-analytics.com https://*.analytics.go https://cloudflareinsights.com; form-action 'self' https://docs.google.com; fr 'none'; base-uri 'self'; object-src 'none'; upgrade-insecure-requests
Strict-Transport-Security	max-age=600; includeSubDomains
Cross-Origin-Opener-Policy	same-origin
Access-Control-Allow-Origin	*

Header	Value
Cross-Origin-Resource-Policy	same-origin

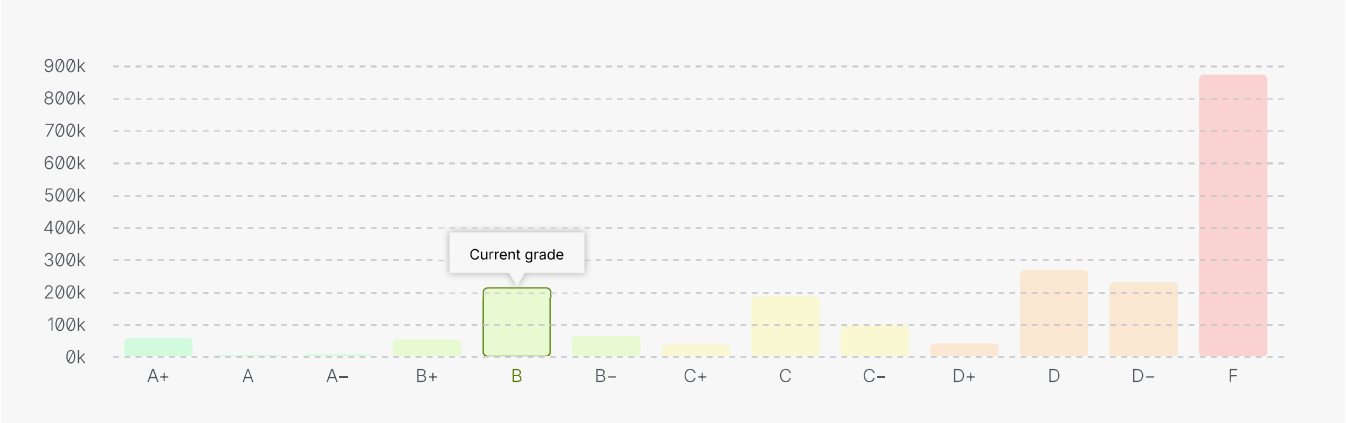
Scan history

Changes in score over time

Date	Score	
2026年4月24日 晚上9:48:28	70	B
2026年4月24日 晚上8:47:19	55	C

Benchmark comparison

Performance trends from the past year



Refer to this graph to assess the website's current status. By following the recommendations provided and rescanning, you can expect an improvement in the website's grade.

mdn_

Your blueprint for a better internet.